

Fundamentals of Software Security **SEng7432**

Chapter One **Fundamentals of Information and Computer Security**

Outline

- ❑ Introduction
- ❑ Objectives of Information & Computer Security
- ❑ Importance of Information & Computer Security
- ❑ Information & Computer Security Challenges
- ❑ Security Attacks
- ❑ Security Services and Mechanisms

Part - I
Fundamentals of Computer
Security

Introduction

➤ What is Security?

- ❑ **Security**, from network point of view, is the protection of the key infrastructure of the network components like computers, links between them and other devices.
 - It is set of activities involved in protecting a valuable item like information.
- ❑ **Computer Security:-** generic name for the collection of tools designed to protect data and to hackers from attacking the organizational assets.
- ❑ **Network Security:-** measures to protect data during their transmission over the network.

Introduction...

➤ What is Security?

- ❑ **Internet Security:**- measures to protect data during their transmission over a collection of interconnected networks(network of networks)
- ❑ **Information Security:**- protection of information and information systems from unauthorized access, use, disclosure, disruption, modification, perusal, inspection, recording or destruction.
- ❑ **Cyber Security:**-

Why computer security?

❑ To protect company assets:

- The primary goals of computer security is protection of company assets (hardware, software and/or information).

❑ To gain a competitive advantage:

- Maintaining effective security measures can provide an organization with a competitive advantage over its competition

❑ To comply with regulatory requirements and fiduciary responsibilities:

- Organizations must develop policies & procedures that address organizational security requirements for continuing operation

Why computer security?

❑ To keep your job:

- Security should be part of every network or systems administrator's job. Failure to perform adequately can result in termination.

❑ Cyber Attack:

- The growing fear of cyber terrorism, attacks to the infrastructure would affect a large portion of the Internet and create a large amount of service disruption.

Challenges in computer security

❑ **Straightforward Requirements:**

- ❑ The requirements seem to be straightforward; one-word labels: confidentiality, authentication, nonrepudiation, or integrity.
- ❑ The mechanisms used to meet those requirements can be quite complex - understanding them may involve rather subtle reasoning.

❑ **Hard to Consider all Potential Attacks:**

- ❑ In developing a particular security mechanism or algorithm, one must always consider potential attacks on those security features.
- ❑ In many cases, successful attacks are designed by looking at the problem in a completely different way, therefore exploiting an unexpected weakness in the mechanism.

Challenges in computer security

❑ **Complex Security Paradox:**

- ❑ The procedures used to provide particular security services are often counter intuitive. A security mechanism is complex, and it is not obvious from the statement of a particular requirement that such elaborate measures are needed.

❑ **Essential Security Mechanism Requirements:**

- ❑ Security mechanisms typically involve more than a particular algorithm or protocol. They also require that participants be in possession of some secret information (e.g., an encryption key), which raises questions about the creation, distribution, and protection of that secret information.

Challenges in computer security

- ❑ **A battle of wits perpetrator vs designer/administrator**
 - ❑ It is a battle of wits between a perpetrator who tries to find holes and the administrator who tries to close them.
 - ❑ The great advantage the attacker has is need only find a single weakness, while the designer must find and eliminate all weaknesses to achieve perfect security.
- ❑ **Strategic Security Deployment:**
 - ❑ Having designed various security mechanisms, it is necessary to decide where to use them.
 - ❑ It is both in terms of physical placement and in a logical sense
- ❑ **Users' natural tendency to**
 - ❑ There is a natural tendency on the part of users and system managers to perceive little benefit from security investment until a security failure occurs.

Challenges in computer security

❑ Regular and Constant Monitoring

- ❑ Security requires regular, even constant, monitoring, and this is difficult in today's short-term, overloaded environment.

❑ Security is Afterthought

- ❑ Security is still too often an afterthought to be incorporated into a system after the design is complete rather than being an integral part of the design process.

❑ Security and performance tradeoff

- ❑ Viewing strong security as an impediment to efficient and user friendly operation of an information system and examine them leads to identify security threats and mechanisms.

Challenges in computer security

- ❑ Internet infrastructures are vulnerable and Solutions usually require a larger scale of modification
- ❑ Security is only as strong as the weakest link and Attacks can be easily launched and difficult to be traced

Basic Security Measures

- ❑ Security measures are fundamental to safeguarding computer systems and information from threats like hacking, unauthorized access, and data breaches.
- ❑ Implementing basic security practices helps maintain the confidentiality, integrity, and availability of information in the digital realm.
- ❑ **External security:**
 - ❑ Protection of computer systems from environmental damages such as floods and heat, physical security such as locking rooms and computers and electrical protection such as power surge and electromagnetic interfaces.
- ❑ **Operational security:**
 - ❑ Deciding who has access to what, limiting access time and location

Basic Security Measures

❑ Surveillance:

- ❑ Proper placement of a security cameras and can deter theft and vandalism

❑ Passwords/authentication:

- ❑ The most common form of security. There are some simple rules for password security systems like:
 - ❑ Change your password often
 - ❑ Pick a good, strong and random password
 - ❑ Don't share password or write down them
 - ❑ Don't select/use names and familiar objects as password

❑ Authentication:

- ❑ The process of reliably verifying the identity of someone/something by means of a secret (password), an object (smart card), physical characteristics (finger print) and trust.

Basic Security Measures

- ❑ **Auditing:** Detecting wrong doing
- ❑ **Access rights:** Determines the security by means of who and how.
 - ❑ Who do you give access right to? (No One, Group of Users, entire set of Users).
 - ❑ How a user/group of user does has access? (Read, write, delete, print, copy, execute).
- ❑ **Antivirus Software and Tools**
 - ❑ Guarding against malware and viruses
- ❑ **Firewalls, Encryption & Decryption and Digital Signature**
 - ❑ Protecting against unauthorized access to resources
- ❑ **Regular Updates:** Keeping software up-to-date to mitigate vulnerabilities.
- ❑ **Security Policy**

Security Vulnerability

- ❑ Computer systems today have the best security systems ever; they are more vulnerable than ever before.
- ❑ Computer and network security comes in many forms: encryption algorithms, access to facilities, digital signatures, fingerprints and face scans as passwords.
- ❑ The OSI security architecture provides a systematic framework for defining security attacks, mechanisms and services.
 - **Security Attack:-** Any action that compromises the security of information owned by an organization.
 - **Security Mechanism:-** A process that is designed to detect, prevent, or recover from a security attack.
 - **Security Service:-** A processing or communication service that enhances the security of the data processing systems and the information transfers of an organization

Security Vulnerability

- ❑ Vulnerabilities(Attack Surface):-
 - Are weak points or loopholes in security that an attacker can exploit in order to gain access to the network or to resources on the network.
- ❑ The vulnerability is not the attack, but rather the weak point that is exploited.
- ❑ Vulnerability is the intersection of three elements:
 - A system susceptibility or flaw,
 - Attacker access to the flaw, and
 - Attacker capability to exploit the flaw
- ❑ To be vulnerable, an attacker must have at least one applicable tool or technique that can connect to a system weakness.

Security Vulnerability

- ❑ A security risk may be classified as a vulnerability.
 - But there are vulnerabilities without risk, for example when the affected asset has no value.
- ❑ A vulnerability with one or more known instances of working and fully-implemented attacks is classified as an exploitable vulnerability, a vulnerability for which an exploit exists.
- ❑ **Vulnerability Classification:**
 - According to the asset class they related to vulnerabilities are classified as: Hardware, Software, Network, Site, organizational and Personnel
 - Personnel Vulnerabilities:
 - Inadequate recruiting process
 - Inadequate security awareness

Security Vulnerability

□ Vulnerability Classification:

○ Hardware

- Susceptibility to humidity, dust and soiling
- Susceptibility to unprotected storage

○ Software

- Insufficient testing
- Lack of audit trail

○ Network

- Unprotected communication lines
- Insecure network architecture

○ Site

- Area subject to flood
- Unreliable power source

○ Organizational

- Lack of regular audits
- Lack of continuity plans

Tips for computer & network security

- ❑ Use a good anti-virus program
- ❑ Make sure your virus definitions are up-to-date
- ❑ Run regular virus scans
- ❑ Update your operating system regularly
- ❑ Configure and use a firewall
- ❑ Use your Web browser's security features
- ❑ Enable your router's security features
- ❑ Install an anti-spyware program
- ❑ Use strong, varied passwords
- ❑ Consider a computer network security suite and policy

Part - II Information System Security

Components of Information System Security

- ❑ The basic components of information security are Confidentiality, Integrity and Availability (C.I.A).
- ❑ These three components are the fundamental objectives of computer network and Information security.

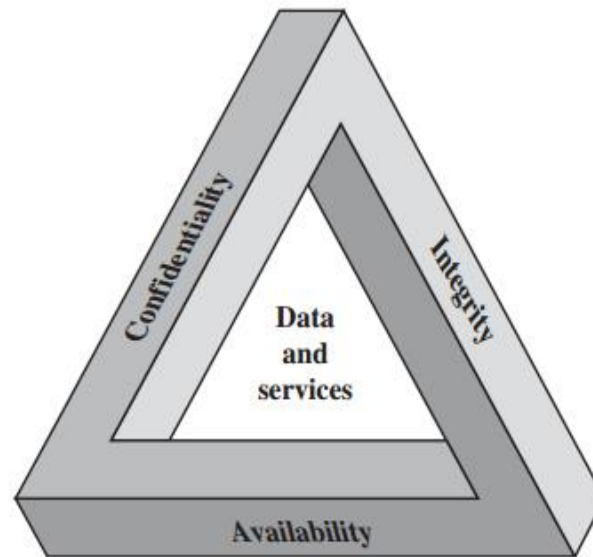


Figure 1: The Security Requirements Triad

Components of Information System Security

❑ Confidentiality:

- Information has confidentiality when it is protected from disclosure or exposure to unauthorized individuals or systems.
- Confidentiality ensures that only those with the rights and privileges to access information are able to do so.
- When unauthorized individuals or systems can view information, confidentiality is breached.
- Measures to protect confidentiality of information:
 - Information classification
 - Secure document storage
 - Application of general security policies
 - Education of information custodians and end users

Components of Information System Security

□ Integrity:

- Information has integrity when it is whole, complete, and uncorrupted.
- The integrity of information is threatened when the information is exposed to corruption, damage, destruction, or other disruption of its authentic state.
- Corruption can occur while information is being stored/transmitted
- integrity is the cornerstone of information systems, because information has no value/use if users cannot verify its integrity.

Components of Information System Security

❑ Integrity:

- Key methods for assuring information integrity:
 - File hashing
 - Look for changes in file integrity as shown by the size of the file
 - Audit your Audit Trails
 - Change Control

❑ Availability:

- Enables authorized users—persons or computer systems—to access information without interference or obstruction and to receive it in the required format.
- The assurance that the service will be available when it's needed

Components of Information System Security

□ Availability:

- Assuring information and communications services will be ready for use when expected
- Factors that affect the availability of Information and Information Security System (threats)
 - Files stored in personal directories may not be available to other employees when needed
 - Hardware failures could affect the availability of company resources
 - A failure in the data circuit could prohibit system access
 - Upgrades in the software may prohibit access

Principles of Information System Security

- ❑ Information Security principles are the basic guidelines that could be used when designing a secure system
- ❑ There are many best practices in Information security that are specific to certain industries or businesses, but some apply broadly.
- ❑ **Balance Protection With Utility:**
 - Deals in Information System Security the way of finding a balance between resource availability, the confidentiality and integrity of the resources. Rather than trying to protect against all kinds of threats, focus on insulating the most vital systems first and then finding acceptable ways to protect the rest without making them useless.

Principles of Information System Security

❑ Split up the Users and Resources:

- Know who is allowed to see and do particular things
- A system administrator needs to assign access by a person's job type, and may need to further refine those limits according to organizational separations.

❑ Assign Minimum Privileges:

- An individual should be assigned the minimum privileges needed to carry out his or her responsibilities.

❑ Use Independent Defenses:

- Using one really good defense, such as authentication protocols, is only good until someone breaches it.
- Introducing several independent defenses may introduce complexity, but doesn't provide 100% protection against attacks, but it does reduce the chances of a successful attack.

Principles of Information System Security

❑ Plan for Failure:

- Having backup systems in place beforehand allows constantly monitor security measures and react quickly to a breach.
- This will help to minimize the impact of potential risks that will occur
- If the breach is not serious, the business or organization can keep operating on backup while the problem is addressed.

❑ Record, Record, Record:

- Ideally, a security system will never be breached, but when a security breach does take place, the event should be recorded.
- Sometimes the causes of breaches aren't apparent after the fact, so it's important to have data to track backwards.
- Data from breaches will eventually help to improve the system and prevent future attacks - even if it doesn't initially make sense.

Principles of Information System Security

❑ Run Frequent Tests:

- Hackers are constantly improving their craft, which means information security must evolve to keep up.
- IT professionals run tests, conduct risk assessments, reread the disaster recovery plan, check the business continuity plan in case of attack, and then do it all over again.

Information Security Policy

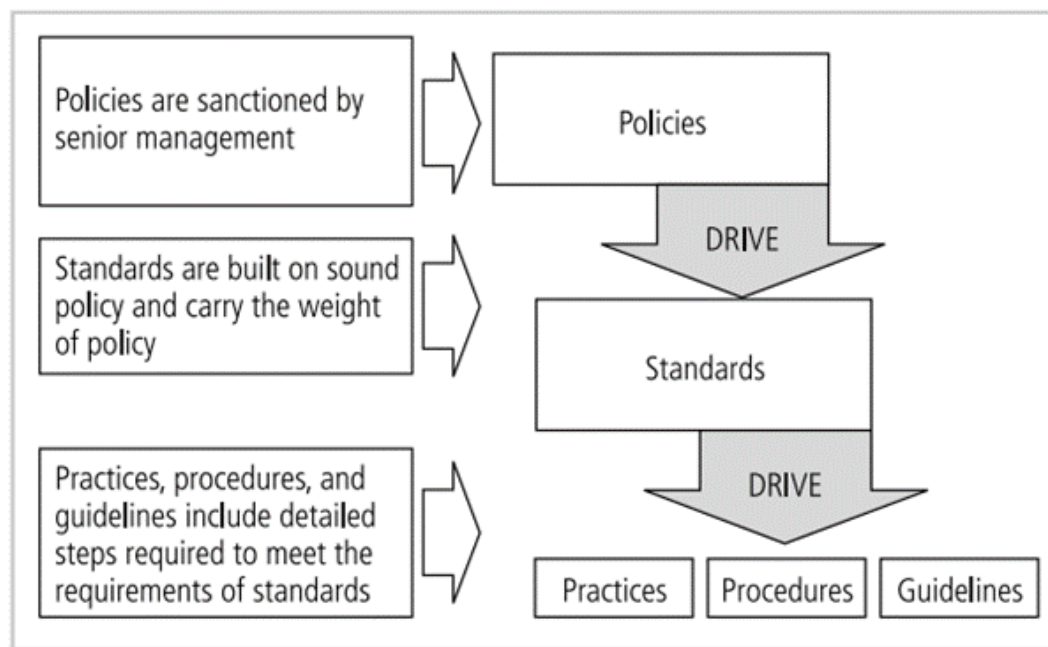
- ❑ A document or set of documents that states an organization's intentions and decisions on what and how electronic information should be secured
- ❑ A statement of what is allowed and what is not allowed
- ❑ It is a set of rules and practices that specify or regulate how a system or organization provides security services to protect sensitive and critical system resources.
- ❑ The set of rules laid down by the security authority governing the use and provision of security services and facilities.
- ❑ Typically created by the CIO in conjunction with CEO and CISO, set the tone for all the subsequent security activities

Information Security Policy

- ❑ The creation and maintenance of these elements require coordinated planning. (strategic and contingency planning)
- ❑ The meaning of security policy depends on the context of in which it is used.
 - Government agencies
 - Credit card agencies
- ❑ The foundation for the information security architecture and blueprint: policy, standard and practices
 - **Policies:-** Like laws, they define what is right, what is wrong, what the penalties are for violating policy and what the appeal process is.
 - Put in place to support the mission, vision and strategic planning of an organization

Information Security Policy

- **Standards:**- more detailed statements of what must be done to comply with policy.
 - Have the same requirements for compliance as policies
 - May be informal or part of an organizational culture
 - May be published, scrutinized and ratified by group
- **Practices, Procedures and Guidelines:**- effectively explain how to comply with policy.



Information Security Policy

- ❑ Three types of security policies that must be defined by management (NIST SP-800-14)
 - Enterprise Information Security Policies
 - Issue-Specific Security Policies
 - Systems-Specific Security Policies
- ❑ For a policy to be effective and thus legally enforceable, it must meet the following criteria:
 - Dissemination (distribution)
 - Review (reading)
 - Comprehension (understanding)
 - Compliance (agreement)
 - Uniform enforcement

Information Security Policy

❑ Dissemination (distribution)

- Demonstrate that the policy has been made readily available for review
- Common dissemination techniques include hard copy and electronic distribution

❑ Review (reading)

- Demonstrate that it disseminated the document in an intelligible form, including versions for illiterate, non-English reading, and reading-impaired employees.
- Common techniques include recording the policy in English and other languages

❑ Comprehension (understanding)

- Demonstrate that the employee understood the requirements and content of the policy
- Common techniques include quizzes and other assessments

Information Security Policy

❑ Compliance (agreement)

- Demonstrate that the employee agrees to comply with the policy, through act or affirmation.
- Common techniques include logon banners which require a specific action (mouse click or keystroke) to acknowledge agreement, or a signed document clearly indicating the employee has read, understood, and agreed to comply with the policy.

❑ Uniform enforcement

- Demonstrate that the policy has been uniformly enforced, regardless of employee status or assignment.

Implementing of Information Security

- ❑ The knowledge and ability to design and implement an effective security program requires:
 - Substantial research, and
 - Large investment of time and resources
 - Home users lack the knowledge and experience to identify and understand their risk
 - Small businesses may understand, they either do not grasp the severity of the problem, or lack the resources to rectify it
- ❑ Design may be based on:
 - Event Driven: started in response to some security breach
 - Plan Driven: Developed in SDLC implementation strategy

Part - III

Attack types and Protection schema

Security Protection Schema

- ❑ A Security Prevention Schema is the foundation of any effective security strategy.
 - Outlines the methods and technologies used to deter, stop, or hinder security threats from reaching or exploiting target systems and data.
- ❑ Security Trinity: the foundation for all security policies and measures that an organization develops and deploys.
 - ❑ The three legs of the "security trinity," prevention, detection, and response, comprise the basis for network security.



Security Protection Schema

□ Prevention:-

- Is the foundation of the security trinity
- Provide some level of security, it is necessary to implement measures to prevent the exploitation of vulnerabilities.
- In developing network security schemes, organizations should emphasize preventative measures over detection and response.
- It is easier, more efficient, and much more cost-effective to prevent a security breach than to detect or respond to one.

Security Protection Schema

□ Detection:-

- Once preventative measures are implemented, procedures need to be put in place to detect potential problems or security breaches, in the event preventative measures fail.
- The sooner a problem is detected the easier it is to correct and cleanup.

□ Response:-

- Organizations need to develop a plan that identifies the appropriate response to a security breach.
- The plan should be in writing and should identify who is responsible for what actions and the varying responses and levels of escalation.

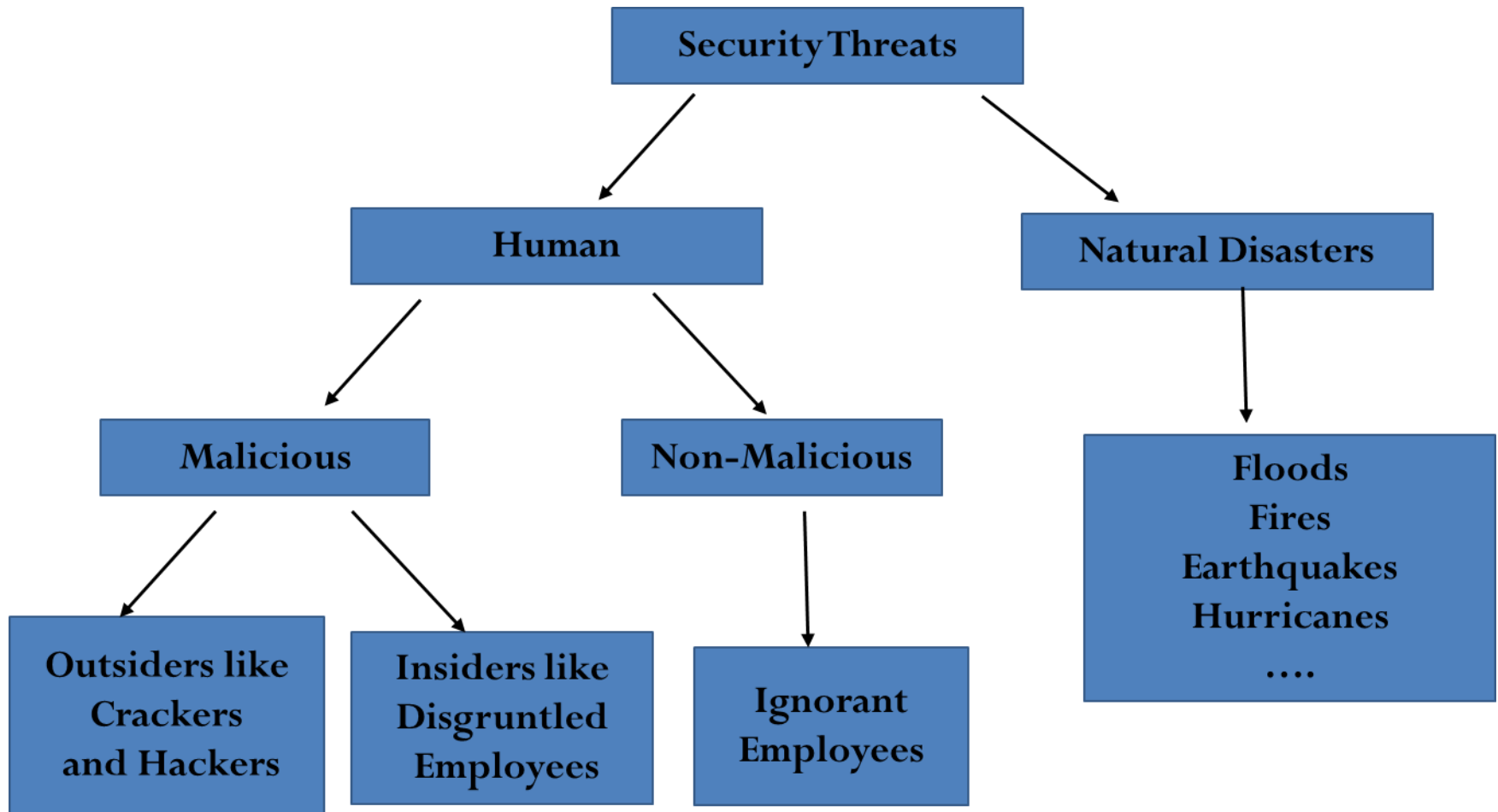
Threats, Attacks & Vulnerabilities

❑ Security Threats:

- ❑ A possible danger that might exploit a vulnerability to breach security and thus cause possible harm.
- ❑ The threat comes from others who would like to acquire the information or limit business opportunities by interfering with normal business processes.

Threats, Attacks & Vulnerabilities

❑ Security Threats:



Threats, Attacks & Vulnerabilities

❑ Natural Disaster:-

- Nobody can stop nature from taking its course.
- Earthquakes, hurricanes, floods, lightning, & fire can cause severe damage to computer systems
- Information can be lost, downtime or loss of productivity can occur, and damage to hardware can disrupt essential services.
- Few safeguards can be implemented against natural disasters, to have disaster recovery plans and contingency plans in place.
- Other threats such as riots, wars, and terrorist attacks could be included here.
 - Although they are human-caused threats and classified as disastrous.

Threats, Attacks & Vulnerabilities

❑ Human Threats: Non-Malicious Threats:

- The primary threat to data integrity comes from authorized users who are not aware of the actions they are performing.
- Errors and omissions can cause valuable data to be lost, damaged, or altered.
- Usually come from employees who are untrained in computers and are unaware of security threats and vulnerabilities.
- Note that ignorant employees usually have no motives and goals for causing damage. The damage is accidental.
- Malicious attackers deceive ignorant employees by using social engineering & gain entry
 - The attacker could masquerade as an administrator and ask for passwords and user names
- Users, data entry clerks, system operators, and programmers frequently make unintentional errors that contribute to security problems, directly or/and indirectly.
 - Error can be a threat, such as a data entry error that crashes a system.

Threats, Attacks & Vulnerabilities

❑ Human Threats:-

- Malicious threats consist of inside attacks by disgruntled or malicious employees and outside attacks by non-employees just looking to harm and disrupt an organization.
- Insiders are the most dangerous attackers - they know many of the codes and security measures in place
- Insiders can affect availability by overloading the system's processing or storage capacity, or by causing the system to crash.
- Disgruntled employees can create both mischief and sabotage on a computer system.
- Examples of Computer-related Employee Sabotage include:
 - Changing/Deleting Data, Destroying data or programs with logic bombs
 - Crashing systems, Holding data hostage
 - Destroying hardware or facilities, Inserting data incorrectly

Threats, Attacks & Vulnerabilities

❑ Hackers:

- People who either break in to systems for which they have no authorization
- Intentionally overstep their bounds on systems for which they don't have legitimate access.
- A programmer who constantly seeks further knowledge, freely share what they have discovered, and never intentionally damage data.

❑ Crackers:

- People who breaks into or otherwise violates system integrity with malicious intent.
- They destroy vital data or cause problems for their targets.
- Common methods for gaining access to a system include password cracking, exploiting known security weaknesses, network spoofing, and social engineering.

Threats, Attacks & Vulnerabilities

- ❑ Malicious attackers normally will have a specific goal, objective, or motive for an attack on a system.
- ❑ Ways to gain Access for deny Services:
 - Viruses
 - Trojan Horses
 - Worms
 - Password Cracking
 - DoS Attacks
 - Email Hacking
 - Intrusion Attack
 - Social Engineering
 - Ping Storm
 - Snuffing
 - Packet Modification
 - Smurfing Attack

Threats, Attacks & Vulnerabilities

- ❑ Attackers trying to harm a system or disrupt normal business operations exploit vulnerabilities by using various techniques, methods, and tools.
- ❑ Attackers generally have motives or goals—for example, to disrupt normal business operations or steal information.
- ❑ To achieve these motives or goals, they use various methods, tools, and techniques to exploit vulnerabilities in a computer system or security policy and controls.
- ❑ Goal + Method + Vulnerabilities = Attack

Threats, Attacks & Vulnerabilities

❑ Actions taken by attackers:

- Deleting and Altering Information:
 - To prove a point - outside attacker
 - To take revenge for something that happened to them - Inside Attacker
- Committing information theft and Fraud
 - By automating traditional methods (Financial Systems, School Grading Systems)
- Disrupting Normal Business process
 - To achieve its specific goal
 - By using various methods (DoS attack)

Threats, Attacks & Vulnerabilities

❑ Denial of Services attacks:-

- A growing trend on the Internet because Web sites in general are open doors ready for abuse.
- Exploits the need to have a service available and prevent legitimate use of services
- DoS attacks flood a remote network with an enormous amount of protocol packets.
- Routers and servers eventually become overloaded by attempting to route or handle each packet, within minutes, network activity exponentially rises and the network stops responding to normal traffic and service requests from clients.
- People can easily flood the Web server with communication in order to keep it busy.
- They are difficult to trace and allow other types of attacks to be subdued.

Threats, Attacks & Vulnerabilities

❑ Denial of Services attacks:-

- Attackers achieve this by flooding a network with more traffic than it can handle.
- Attackers strike with various tools, including Trin00 and Tribe Flood Network (TFN, TFN2K). [Read more on this tools]
- DoS Attacks:
 - Saturating Network Resources: Preventing users from using network resources
 - Disrupting Connections Between two Computers: Preventing communications between services.
 - Preventing a particular individual from accessing a service.
 - Disrupting services to a specific system or client

Threats, Attacks & Vulnerabilities

❑ Denial of Services attacks:

❑ Consuming Server Resources:-

- Preventing the hosts or networks from communicating on the network
- In most cases the victim of such an attack will have difficulty accepting any new, legitimate incoming connections.
- This type of attack does not really affect any of the current connections or outgoing connections, normally it consumes an enormous amount of memory and processing power on the server, causing it to crash.
- The location of the attacking system is difficult to trace because the attacker's system address was masquerading as a legitimate IP address.
- The SYN flood attack
- Use input source filtering to solve such problems

Threats, Attacks & Vulnerabilities

❑ Denial of Services attacks:

❑ Saturating Network Resources:-

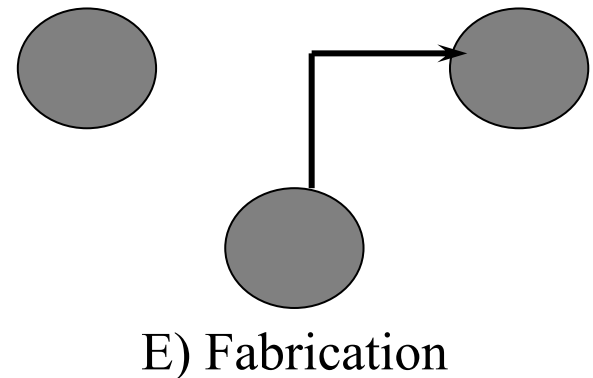
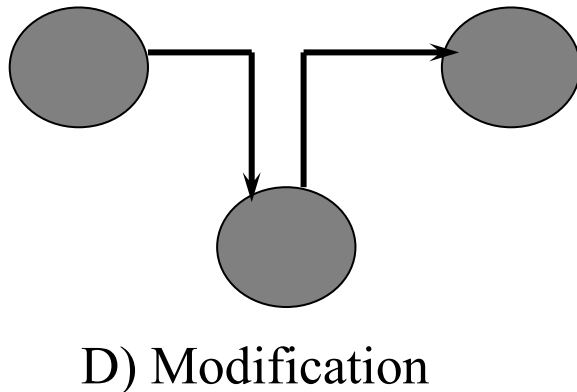
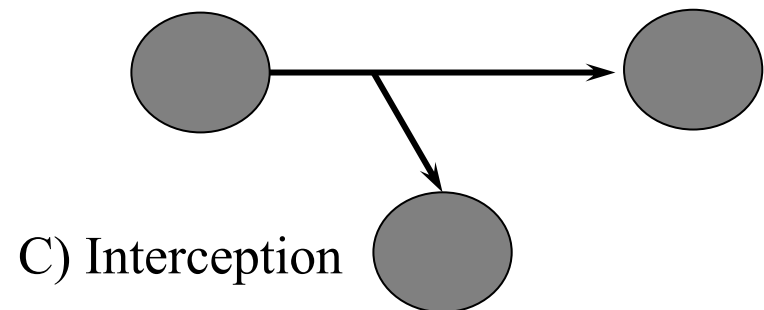
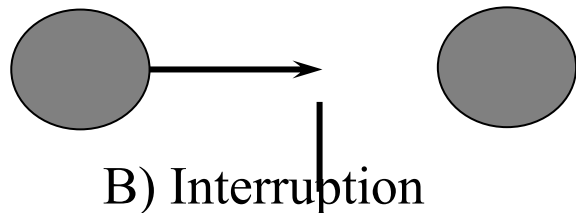
- An intruder may also be able to consume all the available bandwidth on a network by generating a large number of packets directed to the network.
 - Typically, these packets are Internet Control Message Protocol (ICMP) echo packets, but in principle they may be anything.
- Such attacks can be generated from a single computer or from several computers on different networks.
 - This is known as a distributed denial-of-service attack (DDoS).
- ICMP can be used to determine if a computer on the Internet is responding
- Attackers don't use their own IP source address while creating the attack
- Exhaust bandwidth, router processing capacity, or network stack resources, breaking network connectivity to the victims 54

Threats, Attacks & Vulnerabilities

- ❑ Security attack: any action that will compromise the security of information.
 - Is an assault on system security- an intelligent act that is a deliberate attempt to evade security services and violate the security policy of a system.
 - To obtain sensitive information
 - To destroy resources
 - To deny legitimate users access to resources.
- ❑ Security Attack Models:

Threats, Attacks & Vulnerabilities

□ Security Attack Models:



Threats, Attacks & Vulnerabilities

❑ Security Attack Types: Passive Attacks:-

- Do not change or modify the information flowing between the parties.
- Hard to detect - does not involve the other party or alter the data
- Aims to obtain or access information
- Attempt to learn or make use of information from the system
- Don't affect the system resources
- Can be prevented rather than detected
- Example:
 - Eavesdropping / monitoring of traffic
 - Release of message content
 - Traffic Analysis

Threats, Attacks & Vulnerabilities

❑ Security Attacks: Active Attacks:-

- Attempt to alter system resources or affect their operation
- Easier to detect - information stream is altered & involves the other party
- Hard to prevent - no absolute protection
- Modification of data stream
- Creation of false stream
- Examples:
 - Masquerading
 - Reply
 - Modification of Message
 - Denial of Service

Threats, Attacks & Vulnerabilities

❑ Security Mechanisms:

- Tool/set of tools and techniques designed to detect , prevent, or recover from a security attack.
 - Encipherment
 - Digital Signature
 - Access Control
 - Data Integrity
 - Authentication Exchange
 - Traffic Padding
 - Routing Control
 - Notarization

❑ Security Services:

- Procedures and other controls that are implemented to help reduce the risk associated with threat.
- Makes use of one or more security mechanisms
- Some services provide protection from threats, while other services provide for detection of the threat occurrence. (logging or monitoring service)

Threats, Attacks & Vulnerabilities

❑ Security Services:

- For example, the identification and authentication service helps reduce the risk of the unauthorized user threat.
 - Confidentiality/Privacy
 - Integrity
 - Access control
 - Non-Repudiation
 - Authentication
 - Audit
 - Availability

❑ Read more about the following contents

- Typical security threats
- Network infrastructure security problems (Switches, routers, ...)
- Pervasive Security Mechanisms

❑ Assignment - Group

- Choose and discuss one security attack and its preventative mechanism.
- Submission Date: - ***Will be defined in the class with details***